

RGPD

Le **RGPD** (Règlement Général sur la Protection des Données) est une loi européenne qui oblige toutes les entreprises qui collectent des données sur des personnes (clients, employés, utilisateurs...) à les protéger correctement.

La **CNIL** est l'autorité française qui vérifie que les entreprises respectent cette loi. C'est leur site qu'on va utiliser tout au long du projet.

Jour 1 Concepts clés du RGPD - Rapport de conformité RGPD X-corp

RGPD

Le Règlement Général sur la Protection des Données (RGPD) est un règlement européen entré en vigueur le 25 mai 2018. Il encadre la manière dont les organisations collectent, stockent et utilisent les données personnelles des individus résidant dans l'Union Européenne. Son objectif est double : protéger les droits fondamentaux des personnes, et responsabiliser les entreprises qui traitent leurs données.

En France, c'est la **CNIL** (Commission Nationale de l'Informatique et des Libertés) qui est chargée de veiller au respect de ce règlement. Elle peut contrôler les entreprises et prononcer des sanctions pouvant aller jusqu'à **20 millions d'euros ou 4% du chiffre d'affaires mondial**.

Ex: X-corp, entreprise spécialisée dans les solutions logicielles de gestion de données et de marketing digital, est directement concernée par le RGPD. En effet, elle traite quotidiennement les données personnelles de plusieurs millions d'individus pour le compte de ses clients (RetailCo, HealthMed, EduLearn).

Données personnelles

Une **donnée personnelle** est toute information permettant d'identifier directement ou indirectement une personne physique. Cela inclut des informations évidentes comme un nom ou une adresse

email, mais aussi des données plus indirectes comme un identifiant utilisateur ou un historique d'achats.

Certaines données sont considérées comme **sensibles** car leur divulgation peut causer des préjudices importants. C'est le cas des données de santé, qui nécessitent un niveau de protection renforcé.

Ex: Chez X-corp, on identifie deux niveaux de données :

- **Données classiques** : noms, adresses email, numéros de téléphone, historiques d'achats (collectées pour RetailCo et EduLearn)
- **Données sensibles** : historiques médicaux et prescriptions (collectées pour HealthMed) — ces données exigent des mesures de protection particulièrement strictes.

Les 6 principes fondamentaux du RGPD

1. Finalité - Les données ne peuvent être collectées que pour un objectif précis et légitime.

Ex: X-corp collecte les données des clients RetailCo uniquement pour personnaliser les offres commerciales, pas à d'autres fins.

2. Minimisation - On ne collecte que les données strictement nécessaires à l'objectif.

Ex: Pour EduLearn, X-corp collecte les parcours d'apprentissage et résultats d'examen. Des données nécessaires, mais ne devrait pas collecter des données superflues comme la localisation.

3. Transparence - Les personnes doivent être informées de l'usage de leurs données.

Ex: Les patients de HealthMed doivent être clairement informés que leurs données médicales sont traitées par X-corp via son logiciel DataManage.

4. Durée de conservation limitée - Les données ne peuvent pas être gardées indéfiniment.

Ex: X-corp supprime les données RetailCo 5 ans après le dernier contact, celles d'EduLearn après 2 ans, et celles de HealthMed après 10 ans (durée légale pour les données médicales).

5. Sécurité - Des mesures techniques doivent protéger les données.

Ex: X-corp utilise le chiffrement AES-256, la pseudonymisation, et un contrôle d'accès par rôles (RBAC).

6. Conformité continue - La conformité n'est pas un état figé, elle doit être maintenue dans le temps.

Ex: X-corp révisé sa politique de conservation tous les 2 ans.

Les bases légales du traitement

Pour traiter des données personnelles, une organisation doit s'appuyer sur une **base légale**, c'est-à-dire une justification reconnue par le RGPD. Il en existe 6, mais les plus courantes sont :

- **Le consentement** : la personne a explicitement accepté que ses données soient utilisées.
- **L'intérêt légitime** : l'entreprise a un intérêt justifié qui ne porte pas atteinte aux droits des individus.
- **L'obligation légale** : la loi impose de traiter certaines données.

Ex: Chez X-corp :

- RetailCo → base légale : **consentement** des clients
- HealthMed → base légale : **consentement explicite** des patients (renforcé car données sensibles)
- EduLearn → base légale : **consentement** des utilisateurs

Les acteurs du RGPD chez X-corp

Le RGPD distingue plusieurs acteurs avec des responsabilités différentes :

- Le **Responsable de traitement** : c'est l'entité qui décide pourquoi et comment les données sont traitées.

Ex: RetailCo, HealthMed et EduLearn sont responsables de traitement pour leurs propres données clients.

- Le **Sous-traitant** : c'est l'entité qui traite les données pour le compte du responsable.

Ex: X-corp est sous-traitant pour ses clients. CloudSecure (stockage cloud) est lui-même sous-traitant de X-corp.

- Le **DPO (Délégué à la Protection des Données)** : c'est le référent RGPD interne. Il conseille l'entreprise, surveille la conformité et sert de point de contact avec la CNIL.

X-corp a nommé un DPO, ce qui est une bonne pratique (et souvent obligatoire quand on traite des données à grande échelle).

Les droits des personnes concernées

Toute personne dont les données sont traitées dispose de droits qu'elle peut exercer à tout moment :

Droit d'accès Obtenir une copie de ses données Ex: Un client RetailCo peut demander quelles données X-corp possède sur lui.

Droit de rectification Faire corriger des données erronées. Ex: Un patient HealthMed peut corriger une erreur dans son historique médical

Droit à l'effacement Demander la suppression de ses données. Ex: Un utilisateur EduLearn peut demander la suppression de son compte

Droit d'opposition S'opposer à certains traitements. Ex: Un client peut refuser que ses données soient utilisées pour du marketing

Droit à la portabilité Récupérer ses données dans un format réutilisable. Ex: Un utilisateur peut exporter ses données pour les transférer ailleurs

Problème chez X-corp : L'entreprise reçoit entre 50 et 100 demandes d'accès par mois, ce qui représente un volume important et révèle des difficultés à gérer efficacement ces droits.

Les obligations et points de vigilance chez X-corp

L'audit préliminaire de X-corp révèle plusieurs points d'attention :

Points positifs : Un DPO est nommé, des DPIA ont été réalisées pour chaque produit, des mesures de sécurité solides sont en place (chiffrement AES-256, authentification à deux facteurs, RBAC).

Points à améliorer :

- La **gestion des consentements** est défaillante, notamment pour les campagnes marketing via AutoMail : il est difficile de prouver que les consentements ont bien été recueillis et documentés.
- La **gestion d'une violation de données** a montré des lacunes lors de la fuite de 2 000 enregistrements il y a un an. Le processus de réponse n'était pas suffisamment structuré.
- Le volume élevé de **demandes d'accès** (50-100/mois) suggère que les utilisateurs ont du mal à trouver leurs informations ou à exercer leurs droits par eux-mêmes.

Ces points feront l'objet d'analyses approfondies dans les jours suivants (registre des traitements, DPIA, simulation de violation, audit complet).

Conclusion

X-corp, en tant qu'entreprise traitant les données personnelles de plus d'un million et demi d'individus pour le compte de ses clients, est pleinement soumise aux obligations du RGPD. Si des mesures techniques sérieuses ont été mises en place, des fragilités subsistent dans la gestion opérationnelle des consentements et dans le processus de réponse aux incidents. Les prochaines étapes de cet audit (registre des traitements, DPIA, simulation de violation, audit global) permettront d'établir un plan d'action complet pour renforcer la conformité de X-corp.

Jour 2 Registre des Traitements

L'article 30 liste et impose exactement ce qu'un registre des traitements doit contenir. C'est une obligation légale.

- Le nom et les coordonnées du responsable de traitement
- Les finalités du traitement
- Les catégories de personnes concernées
- Les catégories de données collectées
- Les destinataires des données
- Les transferts hors UE éventuels
- Les durées de conservation
- Les mesures de sécurité

La CNIL propose un modèle de registre de base destiné à répondre aux besoins les plus courants en matière de traitements de données.

Ce modèle officiel est structuré en fiches par activité, chacune contenant :

- Les objectifs poursuivis (= la finalité)
- Les catégories de personnes concernées
- Les catégories de données collectées
- Les durées de conservation
- Les destinataires des données
- Les sous-traitants
- Les transferts hors UE
- Les mesures de sécurité

Chaque colonne du tableau correspond à une information obligatoire listée dans l'article 30 du RGPD. La CNIL fournit un modèle officiel sur son site qui structure exactement ces informations. Le tableau permet d'avoir une vue comparative des 3 traitements de X-corp.

REGISTRE DES ACTIVITÉS DE TRAITEMENT	
Entreprise fictive X-corp — Audit RGPD	
Document établi conformément à l'article 30 du RGPD — Source : CNIL (cnil.fr)	
INFORMATIONS SUR L'ORGANISME	
Nom de l'entreprise	X-corp
Secteur d'activité	Technologie et services numériques
Siège social	Paris, France
Effectif	150 employés
Site web	www.X-corp.eu
Année de création	2012
DÉLÉGUÉ À LA PROTECTION DES DONNÉES (DPO)	
Statut du DPO	DPO interne nommé
Rôle	Supervision de la conformité RGPD, conseil, point de contact CNIL
RÔLE DE X-CORP	
Rôle principal	Sous-traitant (traite les données pour le compte de ses clients)
Clients (responsables de traitement)	RetailCo, HealthMed, EduLearn
Partenaires technologiques	CloudSecure (stockage cloud), AdBoost (publicité)
DOCUMENT	
Version	1.0
Date de création	01/09/2026
Prochaine révision	01/09/2028 (révision bisannuelle)
Établi par	Équipe Audit RGPD

REGISTRE DES ACTIVITÉS DE TRAITEMENT — X-CORP (Sous-traitant)				
Article 30 du RGPD Source : CNIL (cnil.fr) Version 1.0 — 01/09/2026				
es	Catégories de personnes concernées	Base légale	Durée de conservation	Destinataires / Accès aux données
III	Clients de RetailCo (environ 800 000 personnes)	Consentement (Art. 6.1.a RGPD) Le client a explicitement consenti à l'utilisation de ses données	5 ans après le dernier contact Puis suppression ou anonymisation	• Équipe marketing RetailCo • Service client RetailCo • Outil AutoMail (campagnes email) • Outil MarketInsight (analyse)
	Patients de HealthMed (environ 500 000 personnes)	Consentement EXPLICITE (Art. 6.1.a + Art. 9.2.a RGPD) ⚠ Données de santé = catégorie spéciale nécessitant un consentement renforcé	10 ans après la fin du traitement médical (Obligation légale secteur santé) Puis archivage sécurisé	• Personnel médical HealthMed • Service de rappel HealthMed • Outil DataManage (gestion dossiers)
	Utilisateurs EduLearn (environ 300 000 personnes)	Consentement (Art. 6.1.a RGPD) L'utilisateur consent lors de son inscription	2 ans après la fin de l'utilisation de la plateforme Puis suppression ou anonymisation	• Équipe pédagogique EduLearn • Outil MarketInsight (analyse comportementale) • Outil AutoMail (relances apprenants)

Jour 3 Réaliser une DPIA

DPIA = Data Protection Impact Assessment = Analyse d'Impact sur la Protection des Données

La DPIA est un outil important pour la responsabilisation des organismes. Elle les aide à construire des traitements de données respectueux de la vie privée et à démontrer leur conformité au RGPD.

Une DPIA se déroule en **4 grandes étapes** :

1. **Décrire** le traitement (c'est quoi, pourquoi, comment)
2. **Évaluer** si c'est nécessaire et proportionné
3. **Identifier les risques** pour les personnes concernées
4. **Proposer des mesures** pour réduire ces risques

La DPIA est **obligatoire** quand un traitement est susceptible d'engendrer un risque élevé. C'est le cas pour "HealthMed" :

- Ce sont des **données de santé** (catégorie sensible)
- Elles concernent **500 000 personnes**
- Elles incluent des historiques médicaux et prescriptions

Outil PIA de la CNIL

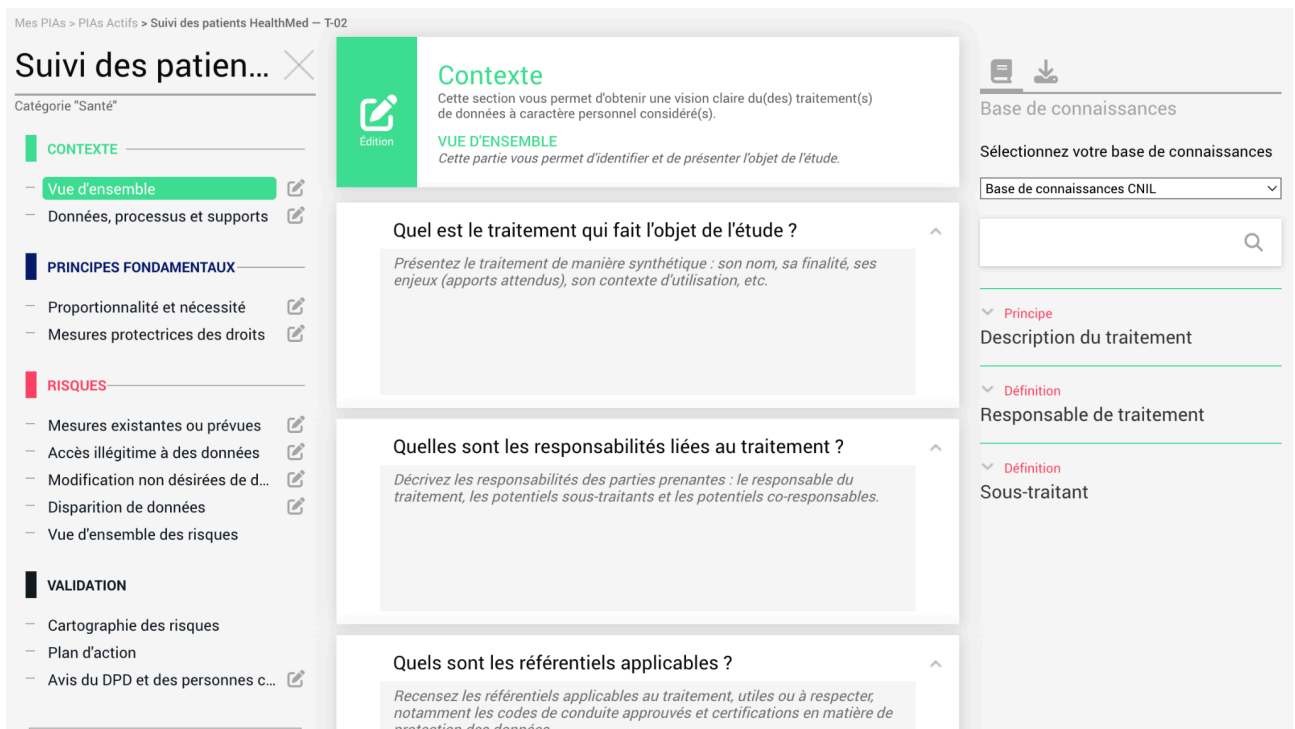
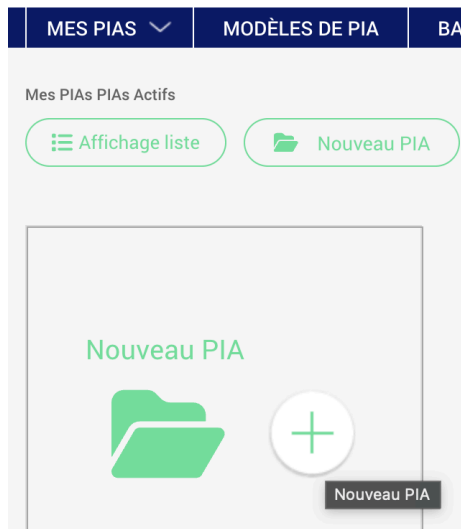


Il s'articule autour de trois axes pour aider à suivre la méthode : une interface ergonomique pour gérer l'ensemble des analyses d'impact, la méthode d'analyse pas à pas pour n'en oublier aucune étape, et des outils de visualisation pour comprendre en un coup d'œil l'état des risques du traitement étudié.

Les avantages :

- Il est officiel (reconnu par la CNIL)
- Il génère un rapport PDF professionnel automatiquement
- Il a des visualisations graphiques des risques (roue des risques, tableau de bord)

Nouveau PIA



Le menu de gauche permet de remplir les données du traitement suivant les 4 étapes du PIA :

- **CONTEXTE** - Décrire le traitement
- **PRINCIPES FONDAMENTAUX** - Vérifier la légitimité
- **RISQUES** - Identifier et évaluer les risques
- **VALIDATION** - Conclure et valider

Visiblement à cause d'un bug du logiciel, les boutons permettant d'éditer sont non-cliquables. On ne peut donc rien remplir en partant d'un nouveau PIA. Par contre en partant d'un modèle de PIA, les champs sont modifiables.

Contexte

Modèles de PIA > HealthMed T-02

HealthMed T-02

CONTEXTE

Vue d'ensemble

Données, processus et supports

PRINCIPES FONDAMENTAUX

Proportionnalité et nécessité

Mesures protectrices des droits

RISQUES

Mesures existantes ou prévues



Contexte

Cette section vous permet d'obtenir une vision claire du(des) traitement(s) de données à caractère personnel considéré(s).

VUE D'ENSEMBLE

Cette partie vous permet d'identifier et de présenter l'objet de l'étude.

Quel est le traitement qui fait l'objet de l'étude ?

X-corp traite, via son logiciel DataManage, les données personnelles de 500 000 patients de HealthMed. Ce traitement inclut la collecte, le stockage et l'exploitation de données médicales sensibles (historiques médicaux, prescriptions) ainsi que des données d'identification (noms, adresses, emails, téléphones). La finalité est le suivi des traitements médicaux, l'envoi de rappels de rendez-vous et la personnalisation des conseils de santé.

Quelles sont les responsabilités liées au traitement ?

Responsable de traitement : HealthMed. Sous-traitant principal : X-corp via DataManage. Sous-traitant secondaire : CloudSecure (stockage cloud). DPO interne nommé chez X-corp.

Quels sont les référentiels applicables ?

RGPD Art. 9 et Art. 35 — Code de la santé publique — Référentiel CNIL Santé — Norme ISO 27001.

+ Ajouter une question

HealthMed T-02

CONTEXTE

- Vue d'ensemble
- Données, processus et supports

PRINCIPES FONDAMENTAUX

- Proportionnalité et nécessité
- Mesures protectrices des droits

RISQUES

- Mesures existantes ou prévues



Contexte

Cette section vous permet d'obtenir une vision claire du(des) traitement(s) de données à caractère personnel considéré(s).

DONNÉES, PROCESSUS ET SUPPORTS

Cette partie vous permet de délimiter et décrire le traitement considéré de manière détaillée.

Quelles sont les données traitées ?

- Données d'identification : noms, prénoms, adresses postales, adresses email, numéros de téléphone
- Données de santé (sensibles - Art. 9 RGPD) : historiques médicaux, prescriptions médicales
- Volume : 500 000 patients concernés
- Durée de conservation : 10 ans après la fin du traitement médical (obligation légale)

Comment le cycle de vie des données se déroule-t-il (description fonctionnelle) ?

- Collecte - Les données patients sont saisies lors de la première consultation médicale via le logiciel DataManage. Le consentement explicite du patient est recueilli à ce moment.
- Stockage - Les données sont chiffrées (AES-256) et stockées sur les serveurs de CloudSecure dans l'Union Européenne.
- Traitement - DataManage analyse les données pour générer des rappels de rendez-vous et personnaliser les conseils de santé. Seul le personnel médical autorisé y accède (contrôle RBAC).
- Archivage - Après la fin du traitement médical, les données sont archivées de manière sécurisée pendant la durée légale de 10 ans.
- Suppression - Au terme des 10 ans, les données sont définitivement supprimées ou anonymisées. Un registre de suppression est maintenu.

Quels sont les supports des données ?

- Logiciel DataManage (X-corp) - traitement et exploitation des données
- CloudSecure - stockage cloud sécurisé
- Outil AutoMail - envoi de rappels de rendez-vous
- Accès via interfaces web sécurisées avec authentification à deux facteurs

Principes Fondamentaux

Modèles de PIA > HealthMed T-02

HealthMed T-02

CONTEXTE

- Vue d'ensemble 
- Données, processus et supports 

PRINCIPES FONDAMENTAUX

- Proportionnalité et nécessité 
- Mesures protectrices des droits 

RISQUES

- Mesures existantes ou prévues 



Principes fondamentaux

Cette section vous permet de bâtir le dispositif de conformité aux principes de protection de la vie privée.

PROPORTIONNALITÉ ET NÉCESSITÉ

Cette partie vous permet de démontrer que vous mettez en œuvre les moyens nécessaires pour permettre aux personnes concernées d'exercer leurs droits.

Les finalités du traitement sont-elles déterminées, explicites et légitimes ?

Oui. Les finalités sont clairement définies et limitées à trois objectifs : le suivi des traitements médicaux des patients, l'envoi de rappels de rendez-vous, et la personnalisation des conseils de santé. Ces finalités sont explicitement communiquées aux patients lors du recueil de leur consentement. Aucune utilisation secondaire des données n'est autorisée.

Quel(s) est(sont) les fondement(s) qui rend(ent) votre traitement licite ?

Le traitement repose sur le consentement explicite des patients (Art. 6.1.a et Art. 9.2.a du RGPD). Ce consentement est obligatoirement recueilli avant toute collecte de données. Il est libre, éclairé, spécifique et révocable à tout moment. Les données de santé étant une catégorie spéciale (Art. 9), un consentement renforcé est requis et appliqué.

Les données collectées sont-elles adéquates, pertinentes et limitées à ce qui est nécessaire au regard des finalités pour lesquelles elles sont traitées (minimisation des données) ?

Oui. Chaque donnée collectée est justifiée par une finalité précise : les données d'identification permettent de contacter le patient, les historiques médicaux et prescriptions sont indispensables au suivi du traitement. Aucune donnée superflue (situation financière, religion, origine ethnique) n'est collectée.

Les données sont-elles exactes et tenues à jour ?

Le personnel médical de HealthMed est responsable de la mise à jour des dossiers patients dans DataManage. Les patients disposent d'un droit de rectification qu'ils peuvent exercer à tout moment auprès de HealthMed. Une procédure de vérification annuelle des données est prévue pour détecter et corriger les informations obsolètes.

Quelle est la durée de conservation des données ?

Les données patients sont conservées 10 ans après la fin du traitement médical, conformément à l'obligation légale du Code de la santé publique français. Passé ce délai, les données sont définitivement supprimées ou anonymisées. Un registre des suppressions est maintenu pour assurer la traçabilité.

HealthMed T-02

CONTEXTE

- Vue d'ensemble 
- Données, processus et supports 

PRINCIPES FONDAMENTAUX

- Proportionnalité et nécessité 
- Mesures protectrices des droits 

RISQUES

- Mesures existantes ou prévues 



Principes fondamentaux

Cette section vous permet de bâtir le dispositif de conformité aux principes de protection de la vie privée.

MESURES PROTECTRICES DES DROITS

Cette partie vous permet de démontrer que vous mettez en œuvre les moyens nécessaires pour permettre aux personnes concernées d'exercer leurs droits.

Comment les personnes concernées sont-elles informées à propos du traitement ?

Les patients sont informés lors de leur première consultation via une notice d'information remise par HealthMed. Cette notice décrit les finalités du traitement, la durée de conservation, leurs droits et les coordonnées du DPO. Une version numérique est également disponible sur l'espace patient en ligne.

Si applicable, comment le consentement des personnes concernées est-il obtenu ?

Le consentement est recueilli par signature d'un formulaire lors de la première consultation (consentement papier) ou via validation électronique sur l'espace patient en ligne. Il est libre, éclairé, spécifique et révoable. Un registre horodaté des consentements est maintenu dans DataManage. Le patient peut retirer son consentement à tout moment en contactant HealthMed ou le DPO de X-corp.

Comment les personnes concernées peuvent-elles exercer leurs droit d'accès et droit à la portabilité ?

Les patients peuvent exercer leur droit d'accès en contactant directement HealthMed par email ou courrier. X-corp s'engage à fournir une réponse dans un délai maximum de 30 jours. Les données peuvent être exportées dans un format structuré et lisible (PDF ou CSV) pour permettre la portabilité.

Comment les personnes concernées peuvent-elles exercer leurs droit de rectification et droit à l'effacement (droit à l'oubli) ?

Toute demande de rectification ou d'effacement est adressée au DPO de X-corp ou directement à HealthMed. La rectification est effectuée dans DataManage sous 30 jours. L'effacement est possible sauf obligation légale de conservation (ex : les 10 ans imposés par le Code de la santé publique priment sur ce droit).

Comment les personnes concernées peuvent-elles exercer leurs droit de limitation et droit d'opposition ?

Les patients peuvent s'opposer à tout moment au traitement de leurs données à des fins de personnalisation des conseils de santé, tout en conservant le suivi médical essentiel. La demande se fait par écrit auprès de HealthMed. X-corp applique la limitation dans DataManage sous 72 heures.

Les obligations des sous-traitants sont-elles clairement définies et contractualisées ?

Oui. Un contrat de sous-traitance conforme à l'article 28 du RGPD est signé entre HealthMed et X-corp, et entre X-corp et CloudSecure. Ces contrats définissent précisément les obligations de chaque partie, les mesures de sécurité requises, et l'interdiction de tout usage secondaire des données.

En cas de transfert de données en dehors de l'Union européenne, les données sont-elles protégées de manière équivalente ?

Aucun transfert de données hors de l'Union Européenne n'est effectué. Les données sont hébergées exclusivement sur les serveurs de CloudSecure situés dans l'UE. Si un transfert hors UE devait avoir lieu à l'avenir, des clauses contractuelles types (CCT) approuvées par la Commission Européenne seraient mises en place.

Risques

Création des mesures

Modèles de PIA > HealthMed T-02

HealthMed T-02

CONTEXTE

— Vue d'ensemble

— Données, processus et supports

PRINCIPES FONDAMENTAUX

— Proportionnalité et nécessité

— Mesures protectrices des droits

RISQUES

Mesures existantes ou prévues

Risques

Cette section vous permet d'apprécier les risques sur la vie privée, compte tenu des mesures existantes ou prévues.

MESURES EXISTANTES OU PRÉVUES

Cette partie vous permet de recenser les mesures (existantes ou prévues) contribuant à la sécurité des données.

+

Créer une mesure (ou en ajouter une proposée dans la base de connaissances à droite)

Chiffrement

Toutes les données patients sont chiffrées en AES-256 au repos sur CloudSecure et en transit sur le réseau. Ce chiffrement protège contre tout accès non autorisé en cas d'interception ou de vol.

Contrôle des accès logiques

L'accès aux données médicales est limité au personnel autorisé via un système RBAC. Chaque connexion nécessite une authentification à deux facteurs. Les droits d'accès sont revus trimestriellement.

Minimisation des données

Seules les données strictement nécessaires au suivi médical sont collectées : identité, coordonnées, historique médical et prescriptions. Aucune donnée superflue n'est traitée.

Sauvegarde des données

Des sauvegardes automatiques quotidiennes sont effectuées par CloudSecure. Des tests de restauration sont réalisés trimestriellement pour garantir la disponibilité des données en cas d'incident.

Contrat de sous-traitance

Un contrat conforme à l'article 28 du RGPD est signé entre HealthMed et X-corp, et entre X-corp et CloudSecure. Ces contrats définissent les obligations de chaque partie et interdisent tout usage secondaire des données.

Sécurisation des canaux informatiques Les échanges de données entre DataManage, CloudSecure et les interfaces utilisateurs sont sécurisés via protocoles TLS 1.3. Aucune donnée médicale ne transite en clair sur le réseau.
Gérer les incidents de sécurité et les violations de données Une procédure de gestion des incidents est en cours de formalisation suite à la fuite de 2 000 enregistrements identifiée. Elle définit les rôles, les délais de notification à la CNIL (72h) et les mesures correctives.
Superviser la protection de la vie privée Le DPO interne de X-corp supervise la conformité RGPD, réalise des audits annuels et constitue le point de contact avec la CNIL. Une révision du PIA est planifiée tous les 2 ans.
Gestion des tiers accédant aux données. CloudSecure et AdBoost sont les seuls tiers autorisés à accéder aux données. Leurs accès sont encadrés contractuellement et audités régulièrement. Aucun accès non contractualisé n'est toléré.

Exportation du modèle (json)

PIA à partir du modèle créé

MES PIAS

MODÈLES DE PIA

BASE DE CONNAISSANCES

Mes PIAs PIAs Actifs

Affichage liste

Nouveau PIA

Importer PIA

Nouveau PIA





ou

Importer PIA





PIA

Suivi des patients HealthMed – T-02

Saisie

Vincent Laplateforme

Évaluation

Cécile Laplateforme

Validation

Quentin Laplateforme

Catégorie

Santé

Modèle

HealthMed T-02

Date

03/09/2026

Statut

En cours

18.75%



Éditer

MES PIAS

MODÈLES DE PIA

BASE DE CONNAISSANCES

Mes PIAs > PIAs Actifs > Suivi des patients HealthMed – T-02

Suivi des patien...

Basé sur le modèle : HealthMed T-02

Catégorie "Santé"

CONTEXTE

Vue d'ensemble

Données, processus et supports

PRINCIPES FONDAMENTAUX

Proportionnalité et nécessité

Mesures protectrices des droits

RISQUES

Mesures existantes ou prévues

Accès illégitime à des données

Modification non désirées de d...

Disparition de données

Vue d'ensemble des risques

VALIDATION

Cartographie des risques

Plan d'action

Avis du DPD et des personnes c...

Valider le PIA

PIÈCES JOINTES

AUCUNE PIÈCE JOINTE

Ajouter

VERSIONS DU PIA

03/09/2026 13:25 - Version actuelle

Créer une nouvelle version

Risques

Cette section vous permet d'apprécier les risques sur la vie privée, compte tenu des mesures existantes ou prévues.

ACCÈS ILLÉGITIME À DES DONNÉES

Analysez les causes et conséquences d'un accès illégitime à des données, et estimez sa gravité et sa vraisemblance.

Quels pourraient être les principaux impacts sur les personnes concernées si le risque se produisait ?

Saisissez les impacts potentiels

Quelles sont les principales menaces qui pourraient permettre la réalisation du risque ?

Saisissez les menaces

Quelles sources de risques pourraient-elles en être à l'origine ?

Saisissez les sources de risques

Quelles sont les mesures initiales, parmi celles identifiées, qui contribuent à traiter le risque ?

Cliquez ici pour sélectionner les mesures contribuant à traiter ce risque.

Comment estimez-vous la gravité du risque, notamment en fonction des impacts potentiels et des mesures prévues ?

(Non définie)

Négligeable

Limitée

Importante

Maximale

Justifiez ici la gravité estimée.

Le bug est toujours présent, on ne peut éditer les risques.

DPIA — Évaluation des risques

Risque 1 — Accès illégitime à des données

Impacts	Divulgence de données médicales, discrimination à l'emploi ou par les assurances, détresse psychologique des patients
Menaces	Cyberattaque, accès frauduleux d'un employé, vol d'identifiants, antécédent de fuite chez X-corp
Sources	Hackers externes, employés malveillants ou négligents
Mesures	Chiffrement AES-256, RBAC, authentification 2 facteurs, sécurisation des canaux
Gravité	Importante
Vraisemblance	Limitée

Risque 2 — Modification non désirée de données

Impacts	Erreur médicale suite à une prescription modifiée, mise en danger de la santé du patient
Menaces	Erreur humaine lors de la saisie, modification malveillante, bug logiciel
Sources	Personnel médical, dysfonctionnement de DataManage
Mesures	Contrôle des accès RBAC, journalisation, traçabilité des modifications
Gravité	Importante
Vraisemblance	Négligeable

Risque 3 — Disparition de données

Impacts	Impossibilité de suivre les traitements en cours, danger médical direct pour les patients
Menaces	Ransomware, panne technique, suppression accidentelle
Sources	Cybercriminels, défaillance technique de CloudSecure
Mesures	Sauvegarde quotidienne, plan de continuité d'activité, contrat de sous-traitance CloudSecure
Gravité	Importante
Vraisemblance	Limitée

Jour 4 Simuler la gestion d'une violation de données chez X-Corp.

1/ Scénario

X-Corp est une entreprise de technologie et de services numériques qui traite, pour son client HealthMed, des données personnelles concernant ses patients (noms, adresses, emails, numéros de téléphone, historique médical et prescription).

Un employé de X-Corp, autorisé à traiter ces données, exporte un fichier contenant les données de 5 000 patients de HealthMed pour réaliser une étude sur le suivi des patients. Mais, lors de l'envoi de fichier par mail, l'employé se trompe de destinataire et l'envoie à une adresse e-mail externe de l'entreprise.

Lorsque l'employé se rend compte de son erreur, il alerte de suite son responsable.

Le DPO ainsi que l'équipe chargée de la sécurité sont alertés afin de prendre en charge l'incident.

X-Corp contacte rapidement le destinataire ayant reçu le fichier par erreur.

Il lui est demandé de ne pas consulter ni transmettre les données du fichier et de le supprimer. Une demande de confirmation de suppression est demandée pour limiter le risque de divulgation.

En parallèle, X-Corp analyse l'incident afin de déterminer précisément les données concernées, le nombre de personnes affectées et les circonstances de la violation. L'entreprise cherche également à déterminer si le fichier a pu être consulté, téléchargé ou transmis à une autre personne.

Ces premières actions permettent à X-Corp de contenir la violation et de disposer des informations nécessaires pour évaluer les risques pour les patients concernés.

2/ Qualifier l'atteinte : confidentialité, intégrité et/ou disponibilité des données.

Dans notre cas de figure, la violation identifiée constitue une atteinte à la confidentialité des données personnelles.

En effet, ce sont des données de santé qui ont fuité. Ces données médicales ne devaient pas être divulguées. Nous sommes donc sur une violation de confidentialité.

Il ne s'agit pas d'une atteinte à l'intégrité puisque les données n'ont pas été modifiées, ni d'une atteinte à la disponibilité puisqu'elles restent accessibles à X-Corp.

3/ Evaluation de niveau de risque pour les droits et libertés des personnes concernées.

Suite à l'analyse de la violation, je qualifierais le niveau de risque pour les personnes concernées comme élevé.

En effet, cette évaluation repose sur plusieurs éléments constatés :

- la nature des données exposées : le fichier contient les historiques médicaux et les prescriptions -> données particulièrement sensibles ;
- le nombre de personnes impactées : 5 000 personnes ;
- le destinataire : le fichier a été transmis à une personne externe non autorisée à accéder à ses informations ;
- les conséquences potentielles : divulgation de données médicales pouvant porter atteinte à la vie privée des patients concernées.

4/ Déterminer les notifications nécessaires

Suite à l'évaluation du niveau de risque, X-Corp doit déterminer les notifications nécessaires conformément aux articles 33 et 34 du RDPG :

- Notification à la CNIL : la violation est susceptible de porter atteinte aux personnes concernées. X-Corp doit notifier l'incident dans les meilleurs délais et, si possible, au plus tard 72h après en avoir pris connaissance à la CNIL.

La notification permettra de présenter l'incident, les données et les personnes concernées, les conséquences potentielles ainsi que les mesures prises ou envisagées par X-Corp pour limiter cette violation de données.

- Information des personnes concernées : le risque étant évalué comme élevé, l'entreprise doit également informer les patients concernés. Cette communication doit leur permettre de comprendre la nature de la violation, ses conséquences potentielles ainsi que les mesures prises par X-Corp.

Exemple de notification à la CNIL :

Objet : Notification de violation de données personnelles — Article 33 RGPD

Nature de la violation : Envoi accidentel par email d'un fichier contenant des données médicales à un destinataire externe non autorisé.

Date et heure de la violation : [date de l'incident]

Date de détection : [date de détection]

Données concernées : Noms, adresses, emails, téléphones, historiques médicaux, prescriptions de 5 000 patients HealthMed.

Personnes concernées : 5 000 patients de HealthMed.

Conséquences potentielles : Divulgation de données médicales sensibles, atteinte à la vie privée, risque de discrimination.

Mesures prises : Contact immédiat du destinataire, demande de suppression confirmée, analyse forensique en cours, renforcement des procédures d'envoi.

Contact DPO : [coordonnées du DPO X-corp]

Exemple de communication aux patients concernés :

Objet : Information importante concernant vos données personnelles

Madame, Monsieur,

Nous vous informons qu'une violation de données vous concernant a eu lieu le [date]. Un fichier contenant vos données médicales a été transmis par erreur à un destinataire externe non autorisé.

Les données concernées sont : votre identité, vos coordonnées, votre historique médical et vos prescriptions.

Nous avons immédiatement contacté le destinataire et obtenu confirmation de la suppression du fichier. Une enquête interne est en cours.

Nous vous présentons nos sincères excuses pour cet incident. Pour toute question, contactez notre DPO à : [email DPO].

Cordialement,
La Direction de X-corp

5/ Documenter l'incident dans un registre interne et proposer des mesures correctives

Conformément à l'article 33 du RGPD, X-Corp documente la violation dans son registre interne des violations de données. Ce registre permet de conserver une trace de l'incident, de ses conséquences et des actions mises en œuvre pour y remédier.

Eléments	Information
Nature de la violation	Envoi accidentel d'un fichier contenant des données sensibles à un destinataire externe par mail
Personnes touchées	5 000 patients de HealthMed
Données concernées	Identité, coordonnées, historique médical, prescriptions
Type d'atteinte	Confidentialité (données médicales)
Niveau de risque	Elevé (données médicales, 5 000 patients)
Cause	Erreur humaine lors de la sélection du destinataire
Notification CNIL	Oui, sous 72H

Personnes informées	Oui
Actions immédiates	Signalement de l'incident et tentative de récupération/suppression du fichier
Mesures correctives	Renforcement des contrôles lors des envoies de données sensibles

Mesures correctives proposées :

Suite à cet incident, X-Corp a renforcé ses procédures afin de limiter le risque qu'une situation similaire se reproduise. L'entreprise a mis en place une vérification renforcée des destinataires lors de l'envoi de données sensibles avec une liste de contacts autorisés et sensibilise les employés aux risques liés aux erreurs d'envoi.

Des mesures techniques peuvent également être mises en place afin de détecter ou bloquer l'envoi de données sensibles vers des destinataires externes non autorisés.

Jour 5 Réaliser un audit de conformité RGPD pour X-Corp.

1/ Introduction

La CNIL indique que pour prouver sa conformité au RGPD, une entreprise doit constituer et regrouper la documentation nécessaire, et que les actions et documents doivent être réexaminés régulièrement pour assurer une protection des données en continu.

Cet audit fait le bilan complet de la conformité de X-corp au RGPD, en s'appuyant sur les travaux réalisés lors des jours précédents (registre des traitements, DPIA, simulation de violation). Il couvre 6 domaines et propose un plan d'action prioritaire.

2/ Résultats de l'audit par domaine

Domaine 1 : Gouvernance et organisation

Critère	Statut	Observations	Recommandation
DPO nommé et opérationnel	✓ Conforme	DPO interne nommé chez X-corp	Publier ses coordonnées sur le site web
Registre des traitements tenu	✓ Conforme	Registre complet pour RetailCo, HealthMed, EduLearn (Art. 30)	Révision bisannuelle planifiée
Politique de protection des données	⚠ Partiel	Politique existante mais non publiée	Publier une politique de confidentialité sur le site
Formation des employés au RGPD	⚠ Partiel	Pas de programme de formation formalisé	Mettre en place une formation annuelle obligatoire
Contrats sous-traitance Art. 28	✓ Conforme	Contrats signés avec CloudSecure et AdBoost	Révision annuelle des contrats

Domaine 2 : Licéité des traitements

Critère	Statut	Observations	Recommandation
Base légale définie pour chaque traitement	✓ Conforme	Consentement pour les 3 traitements, explicite pour HealthMed	RAS
Consentement documenté — RetailCo	⚠ Partiel	Consentements difficiles à prouver pour AutoMail	Mettre en place une CMP (Consent Management Platform)
Consentement documenté — HealthMed	⚠ Partiel	Même problème — risque élevé car données sensibles	Action prioritaire : registre des consentements horodatés
Consentement documenté — EduLearn	⚠ Partiel	Même problème	CMP commune à déployer
Finalités déterminées et respectées	✓ Conforme	Finalités clairement définies dans le registre	RAS

Domaine 3 : Information et droits des personnes

Critère	Statut	Observations	Recommandation
Base légale définie pour chaque traitement	✓ Conforme	Consentement pour les 3 traitements, explicite pour HealthMed	RAS
Consentement documenté — RetailCo	⚠ Partiel	Consentements difficiles à prouver pour AutoMail	Mettre en place une CMP (Consent Management Platform)
Consentement documenté — HealthMed	⚠ Partiel	Même problème — risque élevé car données sensibles	Action prioritaire : registre des consentements horodatés
Consentement documenté — EduLearn	⚠ Partiel	Même problème	CMP commune à déployer
Finalités déterminées et respectées	✓ Conforme	Finalités clairement définies dans le registre	RAS

Domaine 5 : DPIA et gestion des risques

Critère	Statut	Observations	Recommandation
DPIA réalisée pour HealthMed	✓ Conforme	DPIA complète réalisée (Jour 3)	Révision tous les 2 ans
DPIA réalisée pour RetailCo	⚠ Partiel	Non obligatoire mais recommandée à grande échelle	Réaliser une DPIA légère
DPIA réalisée pour EduLearn	⚠ Partiel	Non obligatoire mais recommandée	Réaliser une DPIA légère
Registre des violations tenu	✗ Non conforme	Pas de registre formalisé avant le Jour 4	Adopter le registre créé au Jour 4

Domaine 6 : Transfert des données

Critère	Statut	Observations	Recommandation
DPIA réalisée pour HealthMed	✓ Conforme	DPIA complète réalisée (Jour 3)	Révision tous les 2 ans
DPIA réalisée pour RetailCo	⚠ Partiel	Non obligatoire mais recommandée à grande échelle	Réaliser une DPIA légère
DPIA réalisée pour EduLearn	⚠ Partiel	Non obligatoire mais recommandée	Réaliser une DPIA légère
Registre des violations tenu	✗ Non conforme	Pas de registre formalisé avant le Jour 4	Adopter le registre créé au Jour 4

3/ Tableau de synthèse

Critère	Statut	Observations	Recommandation
DPIA réalisée pour HealthMed	✓ Conforme	DPIA complète réalisée (Jour 3)	Révision tous les 2 ans
DPIA réalisée pour RetailCo	⚠ Partiel	Non obligatoire mais recommandée à grande échelle	Réaliser une DPIA légère
DPIA réalisée pour EduLearn	⚠ Partiel	Non obligatoire mais recommandée	Réaliser une DPIA légère
Registre des violations tenu	✗ Non conforme	Pas de registre formalisé avant le Jour 4	Adopter le registre créé au Jour 4

4/ Plan d'action prioritaire

Critère	Statut	Observations	Recommandation
DPIA réalisée pour HealthMed	✓ Conforme	DPIA complète réalisée (Jour 3)	Révision tous les 2 ans
DPIA réalisée pour RetailCo	⚠ Partiel	Non obligatoire mais recommandée à grande échelle	Réaliser une DPIA légère
DPIA réalisée pour EduLearn	⚠ Partiel	Non obligatoire mais recommandée	Réaliser une DPIA légère
Registre des violations tenu	✗ Non conforme	Pas de registre formalisé avant le Jour 4	Adopter le registre créé au Jour 4

5/ Conclusion

X-corp présente une conformité RGPD partielle mais sérieuse. Les fondations techniques sont solides : chiffrement AES-256, contrôle d'accès RBAC, authentification à deux facteurs, DPO nommé, registre des traitements complet.

Cependant, trois domaines requièrent une attention immédiate :

- La documentation des consentements (problème identifié sur les 3 traitements)
- La gestion des violations de données (fuite de 2 000 enregistrements mal gérée)
- Le traitement des demandes d'accès (50-100/mois sans procédure structurée)

La mise en œuvre du plan d'action prioritaire permettrait d'atteindre un niveau de conformité satisfaisant dans un délai de 6 mois.

6/ Synthèse du projet, lien entre les jours

Jour	Livrable	Apport pour l'audit
Jour 1	Rapport RGPD	Identification des obligations et des acteurs
Jour 2	Registre des traitements	Cartographie des 3 traitements (RetailCo, HealthMed, EduLearn)
Jour 3	DPIA HealthMed	Évaluation des risques et mesures de sécurité
Jour 4	Simulation violation	Procédure de réponse aux incidents et registre des violations
Jour 5	Audit complet	Bilan global et plan d'action — 14 conformes, 12 partiels, 6 non conformes

GLOSSAIRE - PROJET RGPD X-CORP

Termes techniques, notions juridiques et acronymes

Ce glossaire reprend les principaux termes utilisés dans le projet X-Corp, avec des définitions volontairement simples afin de pouvoir les réutiliser dans le rapport ou à l'oral.

Notions fondamentales du RGPD

Terme / acronyme	Signification	Explication simple
RGPD	Règlement Général sur la Protection des Données	Règlement européen qui encadre l'utilisation des données personnelles et protège les droits des personnes.
CNIL	Commission Nationale de l'Informatique et des Libertés	Autorité française chargée de veiller au respect de la protection des données personnelles.
Donnée personnelle	-	Toute information permettant d'identifier directement ou indirectement une personne physique : nom, e-mail, téléphone, identifiant, historique d'achats, etc.
Donnée sensible	-	Donnée nécessitant une protection renforcée, notamment les données de santé utilisées dans le scénario HealthMed.
Traitement de données	-	Toute opération effectuée sur des données : collecte, consultation, stockage, modification, transmission ou suppression.
Finalité	-	Objectif précis pour lequel les données sont collectées et utilisées. En pratique : pourquoi utilise-t-on ces données ?
Minimisation	-	Principe consistant à ne collecter que les données réellement nécessaires à la finalité prévue.
Transparence	-	Obligation d'informer clairement les personnes de la manière dont leurs données sont utilisées.
Durée de conservation	-	Période pendant laquelle les données peuvent être conservées avant leur suppression ou leur anonymisation.
Base légale	-	Justification juridique permettant à une organisation de traiter des données personnelles.
Consentement	-	Accord libre, spécifique, éclairé et univoque donné par une personne pour un traitement déterminé.
Consentement explicite	-	Consentement exprimé de façon claire et explicite. Il peut notamment être requis pour certains traitements de données sensibles.
Intérêt légitime	-	Base légale reposant sur un intérêt justifié de l'organisation, à condition de respecter les droits et libertés des personnes.
Obligation légale	-	Base légale utilisée lorsqu'une règle de droit impose le traitement de certaines données.

Acteurs et droits des personnes

Terme / acronyme	Signification	Explication simple
Responsable de traitement	-	Organisme qui détermine les finalités et les moyens du traitement, c'est-à-dire pourquoi et comment les données sont traitées.
Sous-traitant	-	Organisme qui traite des données personnelles pour le compte du responsable de traitement. Dans le projet, X-Corp est notamment sous-traitant de ses clients.
DPO	Data Protection Officer / Délégué à la Protection des Données	Référent chargé de conseiller l'organisation, de suivre sa conformité RGPD et de servir de point de contact avec la CNIL.

Personne concernée	-	Personne physique dont les données personnelles font l'objet d'un traitement.
Droit d'accès	-	Droit permettant à une personne de savoir quelles données sont détenues sur elle et d'en obtenir une copie.
Droit de rectification	-	Droit de faire corriger des données personnelles inexactes ou incomplètes.
Droit à l'effacement	-	Droit de demander, lorsque les conditions sont réunies, la suppression de ses données personnelles.
Droit d'opposition	-	Droit de s'opposer, dans certaines situations, à l'utilisation de ses données.
Droit à la portabilité	-	Droit de récupérer certaines données dans un format structuré et réutilisable afin notamment de pouvoir les transmettre ailleurs.

Registre, conformité et analyse d'impact

Terme / acronyme	Signification	Explication simple
Registre des traitements	-	Document qui recense et décrit les activités de traitement de données personnelles d'une organisation.
DPIA	Data Protection Impact Assessment	Analyse permettant d'identifier et d'évaluer les risques d'un traitement pour les droits et libertés des personnes, puis de prévoir des mesures pour les réduire.
AIPD	Analyse d'Impact relative à la Protection des Données	Terme français correspondant à la DPIA.
PIA	Privacy Impact Assessment	Expression utilisée pour l'analyse d'impact et pour l'outil PIA de la CNIL utilisé dans le projet.
Risque	-	Possibilité qu'un événement entraîne des conséquences négatives pour les personnes concernées.
Menace	-	Événement ou acteur pouvant provoquer un incident : cyberattaque, erreur humaine, ransomware, etc.
Impact	-	Conséquence possible d'un incident sur les personnes concernées.
Source de risque	-	Origine potentielle du risque : attaquant externe, employé, panne technique, etc.
Gravité	-	Importance des conséquences si le risque se réalise.
Vraisemblance	-	Probabilité estimée qu'un risque se produise.
Audit de conformité	-	Évaluation permettant de déterminer ce qui est conforme, partiellement conforme ou non conforme au RGPD.
Plan d'action	-	Ensemble des mesures à mettre en œuvre pour corriger les non-conformités ou améliorer la protection des données.

Sécurité informatique

Terme / acronyme	Signification	Explication simple
AES-256	Advanced Encryption Standard - 256 bits	Algorithme de chiffrement utilisé pour protéger les données en les rendant illisibles sans la clé appropriée.
Chiffrement	-	Transformation de données lisibles en données illisibles sans la clé de déchiffrement.
RBAC	Role-Based Access Control	Contrôle des accès selon le rôle de l'utilisateur. Chaque personne n'accède qu'aux ressources nécessaires à sa fonction.
2FA	Two-Factor Authentication / authentification à deux facteurs	Méthode de connexion qui demande deux éléments de vérification au lieu d'un seul mot de passe.

Pseudonymisation	-	Technique qui remplace les informations directement identifiantes par des identifiants ou pseudonymes, tout en permettant une ré-identification avec des informations séparées.
Journalisation	-	Enregistrement des événements et actions réalisés dans un système informatique.
Traçabilité	-	Capacité à retrouver qui a réalisé une action, quand et sur quelles données.
Sauvegarde	-	Copie des données permettant de les restaurer en cas de perte ou d'incident.
PCA	Plan de Continuité d'Activité	Organisation et mesures permettant de maintenir ou rétablir les activités essentielles en cas d'incident.
Ransomware	Rançongiciel	Logiciel malveillant qui chiffre ou bloque des données et demande généralement une rançon.
Cyberattaque	-	Action malveillante visant un système informatique, un réseau ou des données.
Analyse forensique	-	Investigation technique réalisée après un incident afin de comprendre ce qui s'est passé et de retrouver des traces numériques.

Violation de données

Terme / acronyme	Signification	Explication simple
Violation de données personnelles	-	Incident de sécurité entraînant notamment la destruction, la perte, la modification, la divulgation ou l'accès non autorisé à des données personnelles.
Confidentialité	-	Principe selon lequel seules les personnes autorisées doivent pouvoir accéder aux données.
Intégrité	-	Principe selon lequel les données doivent rester exactes et ne pas être modifiées de manière non autorisée.
Disponibilité	-	Principe selon lequel les données doivent rester accessibles aux personnes autorisées lorsqu'elles en ont besoin.
Atteinte à la confidentialité	-	Accès ou divulgation de données à une personne non autorisée. C'est le type d'atteinte du scénario du Jour 4.
Atteinte à l'intégrité	-	Modification ou altération non autorisée des données.
Atteinte à la disponibilité	-	Perte, destruction ou indisponibilité des données.
Notification de violation	-	Signalement d'une violation à l'autorité de contrôle lorsque les conditions prévues par le RGPD sont réunies.
Registre des violations	-	Document interne qui conserve la trace des violations, de leurs conséquences et des mesures prises.
Mesure corrective	-	Action mise en place pour corriger un problème et limiter le risque qu'il se reproduise.

Articles du RGPD à connaître

Terme / acronyme	Signification	Explication simple
Article 9 du RGPD	Traitement portant sur des catégories particulières de données personnelles	Encadre notamment le traitement des données de santé. Ces données bénéficient d'une protection renforcée et leur traitement est en principe interdit, sauf dans les cas prévus par le RGPD.
Article 28 du RGPD	Sous-traitant	Encadre la relation entre le responsable de traitement et le sous-traitant, notamment les obligations qui doivent être prévues dans leur contrat.

Article 30 du RGPD	Registre des activités de traitement	Prévoit les informations devant figurer dans le registre des activités de traitement lorsque l'obligation de tenir ce registre s'applique.
Article 33 du RGPD	Notification d'une violation à l'autorité de contrôle	Prévoit la notification d'une violation à l'autorité de contrôle dans les meilleurs délais et, si possible, au plus tard 72 heures après en avoir pris connaissance lorsque la violation est susceptible d'engendrer un risque pour les droits et libertés des personnes.
Article 34 du RGPD	Communication d'une violation à la personne concernée	Prévoit l'information des personnes concernées lorsqu'une violation est susceptible d'engendrer un risque élevé pour leurs droits et libertés.
Article 35 du RGPD	Analyse d'impact relative à la protection des données	Prévoit la réalisation d'une AIPD/DPIA lorsqu'un traitement est susceptible d'engendrer un risque élevé pour les droits et libertés des personnes. Cet article est particulièrement important pour le traitement HealthMed.

Autres acronymes et termes du projet

Terme / acronyme	Signification	Explication simple
UE	Union européenne	Ensemble politique et économique européen. La localisation des traitements et les transferts de données hors UE sont importants dans le cadre du RGPD.
CMP	Consent Management Platform	Plateforme permettant de gérer, enregistrer et conserver la preuve des consentements des utilisateurs.
JSON	JavaScript Object Notation	Format informatique structuré utilisé notamment dans le projet pour l'export du modèle PIA.
PDF	Portable Document Format	Format de document utilisé notamment pour exporter et partager des rapports.
AutoMail	-	Outil fictif de campagnes marketing utilisé dans le scénario X-Corp, pour lequel la preuve des consentements pose problème.
CloudSecure	-	Prestataire fictif de stockage cloud intervenant comme sous-traitant dans le scénario.
DataManage	-	Logiciel fictif de X-Corp utilisé notamment pour le traitement des données HealthMed.

À retenir pour l'oral : RGPD, CNIL, DPO, DPIA/AIPD, articles 9, 30, 33, 34 et 35, AES-256, RBAC, 2FA, ainsi que les notions de finalité, minimisation, base légale, confidentialité, intégrité et disponibilité.